CRISC Mixed Practice Exam III – 100 Real-Life Questions

Weighted to the Four CRISC Domains – Practical Scenarios

CRISC Mastery Series

October 25, 2026

Instructions

How to Use This Deck

Think like a risk practitioner in a real organization.
Focus on business context, ownership, and practical decision-making.
The answer and a key takeaway are on the slide following each question.

Outline

1. Governance (26 percent of the exam)
2. Risk Assessment (20 percent of the exam)
3. Risk Response and Reporting (32 percent of the exam)
4. Information Technology and Security (22 percent of the exam)
5. Conclusion

Q1: Risk Decision Log

Question

Leaders make verbal risk decisions in meetings with no record, and later disagree about what was agreed. What is the **BEST** fix?

(A) Rely on memory

(B) Maintain a decision log capturing the risk, options, decision, owner, and date

(C) Stop holding risk meetings

(D) Assign the practitioner to remember

Q1: Explanation

Correct Answer: B

- Records support accountability.
- Decisions can be reviewed when conditions change.
- Owners and dates prevent confusion.

Key Takeaway

If it is not recorded, it was not decided.

Q2: Board Risk Committee Composition

Question

Which composition **BEST** supports an effective board risk committee?

(A) Only the management team

(B) Members with relevant risk and business expertise and sufficient independence from management

(C) Only technical staff

(D) Members chosen for availability alone

Q2: Explanation

Correct Answer: B

- Independence supports objective oversight.
- Expertise enables informed challenge.
- Mix of skills covers strategic and technical risk.

Key Takeaway

Oversight needs independence and expertise.

Q3: AI Governance Committee

Question

The organization wants to govern the use of AI. Which structure is **MOST** appropriate?

(A) One developer deciding alone

(B) No oversight to encourage speed

(C) Only the marketing team

(D) A cross-functional committee with legal, risk, security, privacy, and business representation and clear decision rights

Q3: Explanation

Correct Answer: D

- AI risks span many disciplines.
- Decision rights prevent gaps.
- Business participation keeps it practical.

Key Takeaway

AI governance is a team sport.

Q4: Model Risk

Question

A statistical model drives pricing decisions. Which governance activity **BEST** manages model risk?

(A) Trust the developer's description

(B) Validate once and never again

(C) Independent validation, documented assumptions, ongoing performance monitoring, and defined ownership

(D) Hide model limitations

Q4: Explanation

Correct Answer: C

- Models can be wrong or drift.
- Independent validation provides assurance.
- Monitoring detects degradation.

Key Takeaway

Validate models independently and keep watching them.

Q5: Climate Risk Governance

Question

Regulators and investors ask about climate-related risks to operations. What should governance do?

(A) Treat it as marketing only

(B) Ignore the question

(C) Leave it to facilities alone

(D) Assign ownership, integrate climate risks into the enterprise risk process, and report them to the board

Q5: Explanation

Correct Answer: D

- Climate can affect operations and supply chains.
- Integration ensures consistent assessment.
- Board visibility supports oversight.

Key Takeaway

Emerging risks belong in the enterprise process.

Q6: Quantified Cyber Risk Reporting

Question

The board asks for cyber risk in terms it can compare with other business risks. What is the **BEST** approach?

(A) Provide only technical vulnerability counts

(B) Provide a list of tools

(C) Translate cyber scenarios into estimated financial impact ranges and compare them to appetite

(D) Avoid quantification entirely

Q6: Explanation

Correct Answer: C

- Financial terms allow comparison.
- Ranges express uncertainty.
- Appetite gives context for decisions.

Key Takeaway

Speak to the board in business terms.

Q7: Culture After a Breach

Question

After a breach caused by human error, management wants to dismiss the employee. What is the **BEST** governance perspective?

(A) Punish without investigation

(B) Hide the cause

(C) Focus on root causes and process or control weaknesses, applying accountability proportionately and fairly

(D) Blame the vendor automatically

Q7: Explanation

Correct Answer: C

- Root causes usually include system factors.
- Fear reduces reporting.
- Fair accountability supports learning.

Key Takeaway

Learn from the failure; do not just blame.

Q8: Security Champions

Question

What is the benefit of a security champions program in business units?

(A) It embeds security awareness and local ownership, improving communication between security and the business

(B) It replaces the security team

(C) It removes policies

(D) It lowers training needs to zero

Q8: Explanation

Correct Answer: A

- Champions are trusted local voices.
- They help translate policy into practice.
- They provide feedback to security.

Key Takeaway

Local champions scale security culture.

Q9: IT Portfolio Prioritization

Question

Many IT projects compete for resources. Which approach **BEST** supports governance?

(A) First come, first served

(B) Loudest sponsor first

(C) Alphabetical order

(D) Prioritize by strategic value, risk, cost, and resource availability using agreed criteria

Q9: Explanation

Correct Answer: D

- Agreed criteria make decisions transparent.
- Risk and value should be balanced.
- Capacity is a real constraint.

Key Takeaway

Prioritize on value, risk, and capacity.

Q10: Stage Gates

Question

A project moves from design to build without reviewing risks or security requirements. Which governance mechanism would have helped?

(A) Longer lunch breaks

(B) Stage gates requiring risk and security approval before proceeding

(C) Faster coding

(D) More meetings without criteria

Q10: Explanation

Correct Answer: B

- Gates enforce review at key points.
- Early detection lowers cost.
- Approval creates accountability.

Key Takeaway

Gates stop problems from rolling forward.

Q11: Architecture Review Board

Question

What is the main purpose of an architecture review board?

(A) To ensure that designs follow standards and consider security, risk, and integration impacts

(B) To select office furniture

(C) To approve vacation requests

(D) To write marketing text

Q11: Explanation

Correct Answer: A

- Consistency reduces complexity.
- Security is reviewed early.
- Exceptions are decided consciously.

Key Takeaway

Review architecture before it becomes legacy.

Q12: Policy Attestation

Question

Why require employees to attest periodically that they have read and will follow key policies?

(A) It removes the need for training

(B) It reinforces awareness, creates accountability, and provides evidence for compliance

(C) It guarantees compliance

(D) It lowers all risk to zero

Q12: Explanation

Correct Answer: B

- Attestation documents acknowledgement.
- It supports enforcement.
- It should complement training.

Key Takeaway

Attestation supports awareness and accountability.

Q13: Data Protection Officer Independence

Question

A designated data protection officer is pressured by management to approve a risky data use. What governance principle applies?

(A) The role must obey every instruction

(B) The role must be able to act independently and report to the highest management level without conflict

(C) The role can be removed for disagreeing

(D) The role should hide concerns

Q13: Explanation

Correct Answer: B

- Independence is important for credibility.
- Direct access to senior management supports escalation.
- Conflicts of interest should be avoided.

Key Takeaway

Oversight roles need independence.

Q14: Shadow AI

Question

Employees use unapproved AI tools to speed up their work. What is the **BEST** governance response?

(A) Provide approved tools and clear usage rules, and monitor for risky use

(B) Ignore it

(C) Ban the internet

(D) Punish everyone

Q14: Explanation

Correct Answer: A

- Bans without alternatives push use underground.
- Rules clarify what data is allowed.
- Monitoring manages residual risk.

Key Takeaway

Enable the safe option and set boundaries.

Q15: Risk Clauses in Contracts

Question

Which contract clauses **BEST** support managing third-party risk?

(A) Only pricing

(B) Only logos

(C) Only delivery dates

(D) Security requirements, breach notification, audit rights, subcontractor controls, and termination assistance

Q15: Explanation

Correct Answer: D

- Clauses create enforceable expectations.
- Notification timelines matter.
- Exit assistance reduces lock-in.

Key Takeaway

Put your risk expectations into the contract.

Q16: Benefits Realization

Question

A project was delivered on time but has not produced the promised business benefits. Which governance practice was weak?

(A) Office decoration

(B) Code formatting

(C) Benefits realization management, including ownership and tracking of expected value

(D) Server cooling

Q16: Explanation

Correct Answer: C

- Delivery is not the same as value.
- Owners must be accountable for benefits.
- Tracking enables corrective action.

Key Takeaway

Governance tracks value, not just delivery.

Q17: Resource Optimization

Question

Risk and security teams are overloaded with low-value tasks. What is the **BEST** governance response?

(A) Add more tasks

(B) Prioritize work by risk, automate routine tasks, and align capacity with objectives

(C) Remove oversight

(D) Ignore the workload

Q17: Explanation

Correct Answer: B

- Resources should focus on high risk.
- Automation frees capacity.
- Alignment avoids waste.

Key Takeaway

Spend scarce expertise where risk is highest.

Q18: Subsidiary Governance

Question

A foreign subsidiary follows weaker security practices than the group standard. What should be done?

(A) Assess the gap, set expectations, assign accountability, and monitor remediation within group governance

(B) Ignore it because it is overseas

(C) Close the subsidiary immediately without analysis

(D) Hide the issue from the board

Q18: Explanation

Correct Answer: A

- Group risk includes subsidiaries.
- Local laws may require adaptation.
- Monitoring ensures progress.

Key Takeaway

The group is exposed to the subsidiary's risk.

Q19: Group vs Local Policy

Question

Local law conflicts with a global policy requirement. What is the **BEST** approach?

(A) Ignore local law

(B) Ignore the global policy

(C) Let each employee decide

(D) Seek legal advice, document the conflict, and adopt a compliant local variant approved by governance

Q19: Explanation

Correct Answer: D

- Legal compliance must come first.
- Documentation explains deviations.
- Governance approval maintains consistency.

Key Takeaway

Resolve conflicts through legal and governance.

Q20: Data Sovereignty

Question

New regulations require certain data to remain within national borders. What should governance do?

(A) Ignore until audited

(B) Identify affected data, assess architecture and vendors, and plan changes to comply

(C) Move all data abroad

(D) Delete the data

Q20: Explanation

Correct Answer: B

- Data location is a compliance requirement.
- Vendors may also be affected.
- Planning avoids rushed changes.

Key Takeaway

Know where regulated data lives.

Q21: Legal Hold

Question

A lawsuit is anticipated. How should the organization treat relevant records?

(A) Delete them quickly

(B) Preserve them under a legal hold, suspending routine deletion for the affected data

(C) Continue normal deletion

(D) Rewrite them

Q21: Explanation

Correct Answer: B

- Destroying evidence creates serious legal risk.
- Legal counsel directs the scope.
- Hold procedures must be communicated.

Key Takeaway

Preserve first, ask questions later.

Q22: Stakeholder Mapping

Question

Why map stakeholders for risk communication?

(A) To avoid communication

(B) To tailor communication to their interests, influence, and information needs

(C) To create conflicts

(D) To hide information

Q22: Explanation

Correct Answer: B

- Different audiences need different messages.
- Influence affects decisions.
- Early engagement builds support.

Key Takeaway

Know who needs to know what.

Q23: Facilitating Risk Workshops

Question

A risk workshop is dominated by one senior person. What is the **BEST** facilitation technique?

(A) Let the senior person decide everything

(B) End the workshop

(C) Use structured input methods such as anonymous voting or round-robin contributions

(D) Ignore the imbalance

Q23: Explanation

Correct Answer: C

- Dominance biases results.
- Structured methods encourage all views.
- Better input improves quality.

Key Takeaway

Structure the discussion to hear everyone.

Q24: Consolidating Registers

Question

Each department keeps its own risk register in a different format. What is the **BEST** improvement?

(A) Keep formats different

(B) Adopt a common structure and criteria so that risks can be consolidated and compared enterprise-wide

(C) Remove registers

(D) Allow only IT to keep one

Q24: Explanation

Correct Answer: B

- Common structure enables aggregation.
- Criteria ensure comparability.
- Enterprise view supports decisions.

Key Takeaway

Standardize to consolidate.

Q25: AI Incident Accountability

Question

An AI system causes a harmful decision. Who remains accountable?

(A) The algorithm

(B) The vendor only

(C) The organization and the designated business owner of the process, not the algorithm or vendor alone

(D) No one

Q25: Explanation

Correct Answer: C

- Accountability stays with people.
- Owners must oversee automated decisions.
- Contracts may share costs but not accountability.

Key Takeaway

Algorithms are not accountable; people are.

Q26: Reporting Concerns Properly

Question

A practitioner believes a material risk is being concealed from the board. What should they do?

(A) Ignore it

(B) Post it publicly at once

(C) Delete the evidence

(D) Escalate through designated channels such as the audit committee, document concerns, and follow the professional code

Q26: Explanation

Correct Answer: D

- Escalation uses proper channels.
- Documentation protects integrity.
- Public disclosure may be a last resort under law.

Key Takeaway

Escalate through proper channels.

Q27: Ransomware Scenario

Question

When building a ransomware scenario, which elements **BEST** support a credible assessment?

(A) The CEO's favorite color

(B) Entry points, backup resilience, recovery times, business impact, and detection capability

(C) Only the ransom amount

(D) Only the number of servers

Q27: Explanation

Correct Answer: B

- Scenarios link cause and impact.
- Recovery capability determines impact.
- Detection affects dwell time.

Key Takeaway

A good scenario covers entry, impact, and recovery.

Q28: Business Email Compromise

Question

Which control **BEST** reduces losses from business email compromise payment fraud?

(A) Out-of-band verification of payment changes and dual approval for large transfers

(B) Larger email attachments

(C) Colorful email templates

(D) Faster payment processing without checks

Q28: Explanation

Correct Answer: A

- Fraud relies on trust in email.
- Independent verification breaks the attack.
- Dual approval limits single-person risk.

Key Takeaway

Verify payment changes through another channel.

Q29: Deepfake Fraud

Question

An attacker uses a synthetic voice to impersonate an executive and requests an urgent transfer. Which response is **BEST**?

(A) Trust the voice

(B) Skip verification for executives

(C) Ignore the threat

(D) Require call-back verification using known numbers and enforce approval procedures regardless of urgency

Q29: Explanation

Correct Answer: D

- Voice alone is no longer reliable proof.
- Procedures should not be bypassed.
- Awareness reduces success.

Key Takeaway

Do not trust urgency or voice alone.

Q30: AI Model Drift

Question

A deployed model's accuracy slowly declines as customer behavior changes. What does the assessment need?

(A) Nothing; models never change

(B) Ongoing monitoring of performance with thresholds and a retraining or review process

(C) One-time testing

(D) Ignoring complaints

Q30: Explanation

Correct Answer: B

- Data and environments change.
- Thresholds trigger action.
- Ownership ensures follow-up.

Key Takeaway

Models need monitoring after deployment.

Q31: Data Poisoning

Question

Which risk arises when attackers manipulate the data used to train a machine learning model?

(A) Data poisoning, which can cause the model to behave incorrectly or in a biased way

(B) Disk overheating

(C) Screen glare

(D) Printer queues

Q31: Explanation

Correct Answer: A

- Training data quality determines behavior.
- Controls include source validation.
- Monitoring may detect anomalies.

Key Takeaway

Protect the data that trains the model.

Q32: Pandemic Scenario

Question

A prolonged pandemic forces most staff to stay away from offices. Which assessment element is **MOST** relevant?

(A) The color of the carpets

(B) Printer supplies

(C) Dependency on critical roles and sites, remote capability, and continuity of essential services

(D) Office plants

Q32: Explanation

Correct Answer: C

- Workforce availability affects operations.
- Remote capability reduces impact.
- Critical roles need backup.

Key Takeaway

Assess dependence on people and places.

Q33: Data Center Loss

Question

Assessing the loss of a primary data center, which factor is **MOST** important?

(A) The building color

(B) The cafeteria menu

(C) Dependencies, recovery capability at an alternate site, and the time to restore critical services

(D) Parking spaces

Q33: Explanation

Correct Answer: C

- Impact depends on recoverability.
- Dependencies determine order.
- Time to restore compares to RTO.

Key Takeaway

Compare recovery capability with business need.

Q34: Cloud Provider Outage

Question

A critical service runs in a single cloud region. What should the assessment consider?

(A) Nothing; clouds never fail

(B) Only cost

(C) Regional failure impact, multi-region or alternative architectures, and recovery objectives

(D) Only logos

Q34: Explanation

Correct Answer: C

- Cloud services can fail.
- Architecture determines resilience.
- Objectives drive design choices.

Key Takeaway

Single region means single point of failure.

Q35: Vendor Financial Health

Question

Why consider the financial stability of a critical vendor in risk assessment?

(A) A vendor failure could disrupt services, support, and data availability

(B) It does not matter

(C) Only the CFO cares

(D) It guarantees security

Q35: Explanation

Correct Answer: A

- Insolvency can end services abruptly.
- Exit plans reduce impact.
- Escrow arrangements may help.

Key Takeaway

Vendor failure is your business risk.

Q36: Credential Stuffing

Question

Attackers use leaked passwords from other sites to log in to customer accounts. Which control **BEST** reduces this risk?

(A) Multi-factor authentication, rate limiting, and detection of unusual login patterns

(B) Shorter passwords

(C) Allow unlimited attempts

(D) Disable logging

Q36: Explanation

Correct Answer: A

- Password reuse is common.
- MFA blocks reuse alone.
- Rate limits and detection limit automation.

Key Takeaway

Assume users reuse passwords.

Q37: SIM Swap

Question

Customers are losing accounts because attackers transfer their phone numbers. Which authentication approach reduces this risk?

(A) Rely only on SMS codes

(B) Avoid relying only on SMS codes; use app-based or hardware authenticators

(C) Remove authentication

(D) Use shorter codes

Q37: Explanation

Correct Answer: B

- Phone numbers can be hijacked.
- Stronger factors are less vulnerable.
- Risk-based step-up can help.

Key Takeaway

SMS alone is a weak second factor.

Q38: Physical Climate Risk

Question

A data center sits in a region with increasing flood risk. What should the assessment consider?

(A) Nothing

(B) Only the building's age

(C) Only the color

(D) Likelihood of flooding, resilience of facilities, insurance, and relocation or redundancy options

Q38: Explanation

Correct Answer: D

- Physical events affect availability.
- Resilience lowers impact.
- Options guide investment.

Key Takeaway

Include physical hazards in IT risk.

Q39: Regulatory Fine Scenario

Question

How should potential regulatory penalties be included in a risk scenario?

(A) As a component of impact, along with remediation costs and reputational damage

(B) They should be ignored

(C) They are the only impact

(D) They are never estimable

Q39: Explanation

Correct Answer: A

- Fines are one cost among many.
- Remediation can exceed fines.
- Reputation affects revenue.

Key Takeaway

Include all impact types, not just fines.

Q40: Open-Source Maintainer Risk

Question

A critical open-source component is maintained by one volunteer who has stopped responding. What is the risk?

(A) No risk

(B) Improved security

(C) Faster updates

(D) Unpatched vulnerabilities and lack of support, requiring contingency such as replacement or internal maintenance

Q40: Explanation

Correct Answer: D

- Unsupported components accumulate risk.
- Inventory identifies dependence.
- Contingency plans reduce impact.

Key Takeaway

Depend on a component, depend on its upkeep.

Q41: Fourth-Party Concentration

Question

Several of your vendors all rely on the same small subcontractor. What does this reveal?

(A) Diversification

(B) No risk

(C) Hidden concentration risk, because one failure could affect many vendors at once

(D) Improved resilience

Q41: Explanation

Correct Answer: C

- Shared dependencies concentrate risk.
- Visibility requires asking about subcontractors.
- Contingency planning is needed.

Key Takeaway

Look for shared dependencies beyond direct vendors.

Q42: Risk Proximity

Question

What does risk proximity describe?

(A) How big the risk is

(B) Who owns the risk

(C) How soon a risk is expected to occur

(D) How much the control costs

Q42: Explanation

Correct Answer: C

- Proximity aids prioritization.
- It complements impact and likelihood.
- Near-term risks need quicker response.

Key Takeaway

Proximity is about timing.

Q43: After a Tool Change

Question

A key security tool is replaced by a new product. What should the risk practitioner do regarding risk ratings?

(A) Keep ratings unchanged

(B) Lower all ratings

(C) Remove the controls

(D) Reassess control effectiveness and coverage during and after the transition

Q43: Explanation

Correct Answer: D

- Transitions often create gaps.
- New tools may behave differently.
- Evidence should confirm coverage.

Key Takeaway

Change in controls means reassessment.

Q44: End-User Computing

Question

Critical financial reports depend on complex spreadsheets maintained by individuals. What is the main risk?

(A) No risk

(B) Errors, lack of version control, and absence of access and change controls

(C) Excess security

(D) Too many backups

Q44: Explanation

Correct Answer: B

- Spreadsheets lack inherent controls.
- Key-person dependency increases risk.
- Governance and testing reduce error.

Key Takeaway

Critical spreadsheets need controls too.

Q45: Industrial Control Assessment

Question

Which consideration is **MOST** important when assessing risk in industrial control systems?

(A) Only confidentiality

(B) Only website design

(C) Only license cost

(D) Safety and availability impacts, with limited ability to patch and test

Q45: Explanation

Correct Answer: D

- Physical consequences can be severe.
- Patching may affect safety.
- Compensating controls are common.

Key Takeaway

For OT, safety and availability lead.

Q46: Assessing Remote Workforce Risk

Question

A company shifts to a largely remote workforce. Which factors should the assessment consider **FIRST**?

(A) Endpoint security, home network exposure, access controls, data handling, and monitoring capability

(B) Only office plants

(C) Only commute times

(D) Only desk size

Q46: Explanation

Correct Answer: A

- Work location changes the threat surface.
- Endpoints and access are critical.
- Monitoring must adapt.

Key Takeaway

Remote work changes the attack surface.

Q47: Incident Playbooks

Question

Responders improvise during phishing incidents with inconsistent results. What is the **BEST** improvement?

(A) Rely on individual judgment only

(B) Delete the process

(C) Develop and exercise playbooks with defined steps, roles, and decision points

(D) Wait for audit

Q47: Explanation

Correct Answer: C

- Playbooks make response repeatable.
- Exercises validate them.
- Roles reduce delay.

Key Takeaway

Playbooks turn improvisation into process.

Q48: Control Library

Question

Teams define controls differently for the same risks. What is the benefit of a central control library?

(A) Consistent control definitions that can be mapped to risks and requirements and reused

(B) More duplicate controls

(C) Less clarity

(D) No ownership

Q48: Explanation

Correct Answer: A

- Reuse saves effort.
- Mapping supports compliance.
- Ownership is clearer.

Key Takeaway

A shared library reduces duplication and confusion.

Q49: Rationalizing Controls

Question

Control testing consumes many resources on low-value controls. What is the **BEST** approach?

(A) Test everything equally

(B) Focus testing on key controls tied to significant risks and reduce effort on low-risk ones

(C) Stop testing

(D) Test only the easiest

Q49: Explanation

Correct Answer: B

- Risk-based testing optimizes resources.
- Key controls give the most assurance.
- Document the rationale.

Key Takeaway

Test what matters most.

Q50: Risk Acceptance Expiry

Question

Why should risk acceptances have an expiry date?

(A) To annoy owners

(B) To avoid acceptance

(C) Conditions change, so acceptance must be revisited and reaffirmed or replaced by a response

(D) To reduce documentation

Q50: Explanation

Correct Answer: C

- Acceptance depends on assumptions.
- Expiry forces review.
- Unreviewed acceptances become stale.

Key Takeaway

Acceptance should expire and be renewed consciously.

Q51: Aging Issues

Question

A report shows many issues open far beyond their target dates. What is the **BEST** action?

(A) Escalate overdue high-risk items, analyze root causes of delays, and reset realistic plans

(B) Ignore the report

(C) Delete old issues

(D) Extend all dates silently

Q51: Explanation

Correct Answer: A

- Aging means exposure persists.
- Root causes may be resourcing or priority.
- Realistic plans improve closure.

Key Takeaway

Overdue issues need escalation and honest replanning.

Q52: Vendor Remediation Escalation

Question

A vendor repeatedly misses remediation dates. Which action is **MOST** appropriate?

(A) Escalate under contract terms, consider penalties or compensating controls, and reassess the relationship

(B) Accept all delays

(C) Remove the finding

(D) Ignore it

Q52: Explanation

Correct Answer: A

- Contracts provide remedies.
- Compensating controls reduce exposure.
- Reassessment may lead to exit.

Key Takeaway

Use contractual levers for repeated delays.

Q53: Service Credits

Question

A provider offers service credits for outages. How should risk be considered?

(A) Credits eliminate the risk

(B) Credits compensate cost but do not remove business impact, so continuity measures are still needed

(C) Credits stop outages

(D) Credits replace backups

Q53: Explanation

Correct Answer: B

- Financial compensation is limited.
- Customers and operations still suffer.
- Resilience remains your responsibility.

Key Takeaway

Credits are not resilience.

Q54: KRIs for AI

Question

Which indicator is **MOST** useful for monitoring an AI system's risk?

(A) Model accuracy trends, bias metrics, override rates, and complaint volumes

(B) Number of servers only

(C) Number of meetings

(D) Marketing clicks

Q54: Explanation

Correct Answer: A

- AI risks include drift and fairness.
- Human override shows trust and errors.
- Complaints reveal harm.

Key Takeaway

Monitor accuracy, fairness, and overrides.

Q55: Tuning DLP

Question

A DLP tool blocks many legitimate transfers and users bypass it. What is the **BEST** response?

(A) Turn it off

(B) Tune policies with business input, balance protection and productivity, and monitor exceptions

(C) Block everything

(D) Ignore user complaints

Q55: Explanation

Correct Answer: B

- False positives drive circumvention.
- Business input improves rules.
- Exceptions need oversight.

Key Takeaway

Controls that block the business get bypassed.

Q56: Backup Test Results

Question

A restore test fails for a critical database. How should this be reported?

(A) Hide it

(B) Report only successes

(C) As a significant control weakness with impact, root cause, remediation plan, and retest date

(D) Consider it minor

Q56: Explanation

Correct Answer: C

- Failure means data may be unrecoverable.
- Retest confirms the fix.
- Transparency supports decisions.

Key Takeaway

Report failed restores clearly.

Q57: Automating Control Evidence

Question

Collecting evidence for controls manually is slow and error-prone. What is the **BEST** improvement?

(A) Automate evidence collection where feasible and validate its accuracy

(B) Stop collecting evidence

(C) Collect less often

(D) Accept errors

Q57: Explanation

Correct Answer: A

- Automation improves consistency.
- Validation ensures reliability.
- Frees time for analysis.

Key Takeaway

Automate evidence to improve quality and speed.

Q58: Board Cyber Report

Question

Which content is **MOST** useful in a board cyber risk report?

(A) Raw logs

(B) Tool brochures

(C) Long technical glossaries

(D) Top risks against appetite, trends, key incidents, control status, and decisions required

Q58: Explanation

Correct Answer: D

- Boards need strategic information.
- Trends and appetite give context.
- Decisions drive action.

Key Takeaway

Report risks, trends, and decisions.

Q59: Incident Severity Levels

Question

Why define incident severity levels in advance?

(A) To hide incidents

(B) To avoid response

(C) To delay decisions

(D) To drive consistent response, escalation, and communication based on impact

Q59: Explanation

Correct Answer: D

- Pre-defined levels speed decisions.
- Escalation paths align with severity.
- Consistency aids reporting.

Key Takeaway

Define severity before the incident.

Q60: Executive Communication During Incident

Question

During a major incident, how often should executives receive updates?

(A) Only at the end

(B) At agreed intervals defined by severity, even if there is no new information

(C) Never

(D) Whenever someone remembers

Q60: Explanation

Correct Answer: B

- Regular updates reduce speculation.
- Cadence supports decisions.
- Silence erodes confidence.

Key Takeaway

Predictable updates build trust.

Q61: Cost of a Breach

Question

Which cost category is often **UNDERESTIMATED** in breach impact?

(A) The price of coffee

(B) Parking fees

(C) Indirect costs such as lost customers, reputational damage, and long-term remediation

(D) Stationery

Q61: Explanation

Correct Answer: C

- Direct costs are easier to see.
- Indirect costs can be larger.
- Include them in scenarios.

Key Takeaway

Do not forget the indirect costs.

Q62: Recovery Priorities

Question

Many systems fail at once. How should recovery be prioritized?

(A) Alphabetically

(B) Randomly

(C) By system age

(D) By criticality to business processes, using BIA results and dependencies

Q62: Explanation

Correct Answer: D

- BIA defines priorities.
- Dependencies set order.
- Business input resolves conflicts.

Key Takeaway

Recover what the business needs first.

Q63: Vendor Exit Execution

Question

A vendor relationship ends. Which activity is **MOST** important to manage risk?

(A) Ignore the transition

(B) Execute the exit plan: transfer data and services, revoke access, and verify deletion

(C) Keep access open

(D) Delete the contract only

Q63: Explanation

Correct Answer: B

- Transition is a risky period.
- Access and data remain exposure.
- Verification provides evidence.

Key Takeaway

Manage exit as a project, not an afterthought.

Q64: Cyber Insurance Claim

Question

After an incident, the organization plans an insurance claim. What should it ensure?

(A) Ignore the policy

(B) Delay notification indefinitely

(C) Evidence, timelines, and notification are handled according to policy terms

(D) Destroy evidence

Q64: Explanation

Correct Answer: C

- Policies have conditions.
- Late notice may affect coverage.
- Documentation supports the claim.

Key Takeaway

Follow the policy's claim procedure.

Q65: Learning From Near Misses

Question

Why record and analyze near misses?

(A) They are meaningless

(B) They create blame

(C) They reveal control weaknesses and improvement opportunities without actual loss

(D) They are illegal to record

Q65: Explanation

Correct Answer: C

- Near misses are early warnings.
- Patterns suggest root causes.
- Learning is cheap compared with loss.

Key Takeaway

Near misses are free lessons.

Q66: Vulnerability Metrics Context

Question

A report states that vulnerabilities fell by 20 percent. What additional context is **MOST** needed?

(A) The font used

(B) Severity, exposure, asset criticality, and whether new scans covered the same scope

(C) The author's name

(D) The time of printing

Q66: Explanation

Correct Answer: B

- Counts alone mislead.
- Scope changes affect comparisons.
- Critical assets matter more.

Key Takeaway

Numbers need context.

Q67: Patch Compliance Reporting

Question

A patch compliance report shows 98 percent, but the remaining 2 percent includes critical servers. What should the practitioner highlight?

(A) That the exposure is concentrated in critical systems, which may represent significant risk

(B) Only the overall 98 percent

(C) Hide the exceptions

(D) Consider the matter closed

Q67: Explanation

Correct Answer: A

- Averages hide concentrated risk.
- Criticality matters.
- Highlight outliers.

Key Takeaway

Do not let averages hide critical exceptions.

Q68: Configuration Drift Reports

Question

What does recurring configuration drift in monitoring reports indicate?

(A) Perfect compliance

(B) No issues

(C) Better security

(D) Weak change control or automation, requiring root cause analysis and preventive measures

Q68: Explanation

Correct Answer: D

- Drift means configurations are changing unmanaged.
- Preventive automation helps.
- Owners should be accountable.

Key Takeaway

Recurring drift points to process weakness.

Q69: Measuring Training Effectiveness

Question

Which indicator **BEST** demonstrates the effectiveness of security training?

(A) Hours spent in class

(B) Improved behavior metrics, such as reduced phishing click rates and increased reporting

(C) Slides per course

(D) Number of attendees

Q69: Explanation

Correct Answer: B

- Behavior shows impact.
- Reporting rates show engagement.
- Attendance alone is weak.

Key Takeaway

Measure what changes, not who attends.

Q70: Phishing Simulation Use

Question

How should phishing simulation results be used?

(A) To guide targeted education and measure trends, without punishing individuals

(B) To fire staff who click

(C) To publish names

(D) To ignore results

Q70: Explanation

Correct Answer: A

- Punishment reduces reporting.
- Targeted support improves behavior.
- Trends show progress.

Key Takeaway

Use simulations to teach, not to shame.

Q71: Response Budget Justification

Question

Which approach **BEST** justifies a budget request for risk response?

(A) Present the risk addressed, expected reduction, cost, and alternatives in business terms

(B) Fear alone

(C) Technical jargon alone

(D) No explanation

Q71: Explanation

Correct Answer: A

- Decision makers need clear value.
- Alternatives show rigor.
- Business terms improve understanding.

Key Takeaway

Make the case in business terms.

Q72: Prioritizing Quick Wins

Question

Some risk responses are quick and cheap, others slow and expensive. How should they be sequenced?

(A) Do only quick wins

(B) Do only the slowest

(C) Do nothing

(D) Consider risk reduction, cost, and dependencies; do quick wins that matter while starting critical longer-term actions

Q72: Explanation

Correct Answer: D

- Balance speed and value.
- Critical risks cannot wait.
- Dependencies affect ordering.

Key Takeaway

Balance quick wins with critical work.

Q73: Aligning Reports With Appetite

Question

Why present risk results relative to risk appetite?

(A) It shows whether exposure is acceptable and where decisions are needed

(B) It hides results

(C) It replaces data

(D) It avoids discussion

Q73: Explanation

Correct Answer: A

- Appetite is the benchmark for acceptability.
- Gaps highlight needed action.
- It supports governance.

Key Takeaway

Appetite gives risk numbers meaning.

Q74: Risk Reporting Frequency

Question

How should reporting frequency be set?

(A) The same for all risks always

(B) Only annually

(C) Based on risk volatility, audience needs, and defined escalation triggers

(D) Only after incidents

Q74: Explanation

Correct Answer: C

- Fast-moving risks need frequent updates.
- Audiences differ.
- Triggers handle exceptions.

Key Takeaway

Frequency follows volatility and need.

Q75: Verifying Remediation Claims

Question

A team claims that a vulnerability has been fixed. What should the practitioner do?

(A) Accept without checking

(B) Close immediately

(C) Verify through rescanning or testing before closing the issue

(D) Ignore it

Q75: Explanation

Correct Answer: C

- Claims need evidence.
- Rescans confirm fixes.
- Verification prevents false assurance.

Key Takeaway

Trust, then verify the fix.

Q76: Communicating Residual Risk

Question

How should residual risk be communicated to decision makers?

(A) Say it is zero

(B) Hide it

(C) Use only technical terms

(D) Explain what remains after controls, its potential impact, and options to reduce it further

Q76: Explanation

Correct Answer: D

- Residual risk is what they accept.
- Impact ties to objectives.
- Options support choice.

Key Takeaway

Make residual risk visible and understandable.

Q77: Metrics for Third-Party Risk Program

Question

Which metric **BEST** shows whether a third-party risk program is effective?

(A) Percentage of critical vendors assessed on schedule, open high-risk findings, and time to remediate them

(B) Number of vendors listed

(C) Number of emails sent

(D) Number of meetings held

Q77: Explanation

Correct Answer: A

- Coverage of critical vendors matters.
- Open findings show exposure.
- Remediation time shows follow-through.

Key Takeaway

Measure coverage, findings, and closure.

Q78: Reporting Control Weaknesses Fairly

Question

How should control weaknesses be reported to management?

(A) Exaggerate to get attention

(B) Objectively, with evidence, impact, and recommended actions, without exaggeration or concealment

(C) Hide minor ones always

(D) Report opinions only

Q78: Explanation

Correct Answer: B

- Credibility depends on accuracy.
- Evidence supports decisions.
- Recommendations enable action.

Key Takeaway

Report objectively and completely.

Q79: SASE

Question

Remote users and branch offices need consistent network security delivered from the cloud. Which model fits?

(A) Secure access service edge, combining networking and security services in the cloud

(B) A single office firewall only

(C) Paper-based access

(D) Dial-up modems

Q79: Explanation

Correct Answer: A

- SASE converges network and security.
- Policies follow users.
- Cloud delivery scales.

Key Takeaway

SASE delivers network and security as a cloud service.

Q80: XDR

Question

What is the main advantage of extended detection and response?

(A) Replacing all staff

(B) Removing logs

(C) Reducing visibility

(D) Correlating telemetry across endpoints, network, email, and cloud for better detection and response

Q80: Explanation

Correct Answer: D

- Cross-domain correlation reveals attack chains.
- Response can be coordinated.
- It needs tuning and skilled analysts.

Key Takeaway

XDR connects signals across domains.

Q81: CASB

Question

The organization needs visibility and policy control over the use of many cloud applications. Which technology helps?

(A) A paper shredder

(B) A cloud access security broker

(C) A label printer

(D) A battery backup

Q81: Explanation

Correct Answer: B

- CASBs discover shadow cloud use.
- They enforce data and access policies.
- They integrate with identity.

Key Takeaway

CASB governs cloud app usage.

Q82: Hardware Security Module

Question

Why use a hardware security module?

(A) To speed up printing

(B) To store paper records

(C) To cool servers

(D) To generate, store, and use cryptographic keys in tamper-resistant hardware

Q82: Explanation

Correct Answer: D

- Keys never leave the module in clear form.
- Tamper resistance protects against theft.
- Access is strongly controlled.

Key Takeaway

HSMs protect keys in hardware.

Q83: Infrastructure as Code

Question

Cloud infrastructure is defined in code templates. Which practice **BEST** reduces risk?

(A) Allow unreviewed changes

(B) Store templates on personal laptops

(C) Scan templates for misconfigurations, use version control and peer review, and enforce policies in pipelines

(D) Skip testing

Q83: Explanation

Correct Answer: C

- Code errors can deploy insecure infrastructure at scale.
- Review and scanning catch issues early.
- Policy enforcement ensures consistency.

Key Takeaway

Treat infrastructure code like application code.

Q84: CI/CD Pipeline Security

Question

Which control **BEST** protects a CI/CD pipeline from compromise?

(A) Least-privilege pipeline access, protected secrets, signed artifacts, and logging of changes

(B) Shared pipeline passwords

(C) Open access

(D) No logs

Q84: Explanation

Correct Answer: A

- Pipelines can push malicious code to production.
- Signing proves integrity.
- Logging supports investigation.

Key Takeaway

Protect the build path to production.

Q85: Kubernetes Risk

Question

A company runs workloads on Kubernetes. Which practice is **MOST** important?

(A) Give all developers cluster admin

(B) Run any image from the internet

(C) Disable logging

(D) Restrict cluster access, apply network policies, scan images, and secure configuration and secrets

Q85: Explanation

Correct Answer: D

- Misconfiguration is a common issue.
- Network policies limit movement.
- Image and secret hygiene matter.

Key Takeaway

Lock down the cluster.

Q86: UEBA

Question

What does user and entity behavior analytics provide?

(A) Faster printing

(B) Physical access control

(C) Detection of anomalous behavior by comparing activity to established baselines

(D) Hardware cooling

Q86: Explanation

Correct Answer: C

- Baselines reveal unusual activity.
- It helps detect compromised accounts and insiders.
- Tuning reduces false positives.

Key Takeaway

Spot behavior that differs from normal.

Q87: Deception Technology

Question

What is the main purpose of honeypots and deception technology?

(A) To increase bandwidth

(B) To replace firewalls

(C) To lure attackers into decoys, detect their activity early, and learn their techniques

(D) To store backups

Q87: Explanation

Correct Answer: C

- Decoys generate high-confidence alerts.
- They reveal attacker behavior.
- They complement other controls.

Key Takeaway

Decoys detect attackers early.

Q88: BGP and Routing Risk

Question

Which risk is associated with weak internet routing security?

(A) Faster internet always

(B) Better privacy always

(C) Fewer outages

(D) Traffic could be misdirected or intercepted through route hijacking

Q88: Explanation

Correct Answer: D

- Routing relies on trust between networks.
- Monitoring and validation reduce risk.
- Encryption protects content in transit.

Key Takeaway

Routing can be hijacked; encrypt traffic.

Q89: Email Gateway Security

Question

Which capability should a secure email gateway provide?

(A) Blocking all email

(B) Printing emails

(C) Filtering for spam, malware, and phishing, plus attachment and link inspection

(D) Deleting archives

Q89: Explanation

Correct Answer: C

- Email is a primary attack vector.
- Inspection catches malicious content.
- Policy enforcement reduces risk.

Key Takeaway

Filter the main attack path.

Q90: Passkeys

Question

Which technology can reduce phishing risk by using cryptographic credentials tied to a device and website?

(A) Longer typed passwords only

(B) Security questions

(C) Shared passwords

(D) Passkeys using public-key cryptography

Q90: Explanation

Correct Answer: D

- Credentials are bound to the legitimate site.
- No shared secret is sent.
- Devices protect the private key.

Key Takeaway

Passkeys resist phishing.

Q91: MFA Fatigue

Question

Attackers bombard a user with approval prompts until the user accepts one. Which control **BEST** counters this?

(A) Allow unlimited prompts

(B) Number matching or context in prompts, limits on prompts, and training

(C) Disable MFA

(D) Use SMS only

Q91: Explanation

Correct Answer: B

- Prompt bombing exploits annoyance.
- Number matching makes approvals deliberate.
- Limits and monitoring detect abuse.

Key Takeaway

Make MFA approvals deliberate.

Q92: Password Managers

Question

Why might an organization encourage password managers?

(A) They enable unique, strong passwords for each service without users memorizing them

(B) They remove the need for any security

(C) They reuse the same password

(D) They disable MFA

Q92: Explanation

Correct Answer: A

- Reuse is a major risk.
- Managers should be protected with MFA.
- They reduce weak password behavior.

Key Takeaway

Unique passwords for every service.

Q93: Prompt Injection

Question

A chatbot connected to company data follows malicious instructions hidden in user-provided content. What is this attack?

(A) Disk failure

(B) Cable damage

(C) Screen flicker

(D) Prompt injection

Q93: Explanation

Correct Answer: D

- Models can follow untrusted instructions.
- Mitigation includes isolation and output controls.
- Limit the model's access and actions.

Key Takeaway

Treat model inputs as untrusted.

Q94: Model Theft and Leakage

Question

What is a risk of exposing a proprietary machine learning model through a public interface?

(A) No risk

(B) Better performance

(C) Attackers could extract the model or sensitive training data through repeated queries

(D) Lower cost always

Q94: Explanation

Correct Answer: C

- Queries can reveal model behavior.
- Rate limits and monitoring help.
- Sensitive data should be minimized in training.

Key Takeaway

Public models can leak what they learned.

Q95: Log Management Architecture

Question

Which design **BEST** supports reliable log management?

(A) Logs only on local devices

(B) Logs editable by all

(C) No retention

(D) Centralized collection, time synchronization, protection from tampering, and defined retention

Q95: Explanation

Correct Answer: D

- Central logs support correlation.
- Integrity supports investigations.
- Retention meets obligations.

Key Takeaway

Centralize, protect, and retain logs.

Q96: DNSSEC

Question

What does DNSSEC provide?

(A) Authentication and integrity of DNS data, helping prevent spoofed responses

(B) Encryption of all web content

(C) Faster browsers

(D) Spam filtering

Q96: Explanation

Correct Answer: A

- Signatures validate DNS answers.
- It does not encrypt traffic.
- It reduces poisoning risk.

Key Takeaway

DNSSEC authenticates DNS answers.

Q97: PKI Trust

Question

Why is protecting a certificate authority's private key critical?

(A) It only affects speed

(B) It has no impact

(C) Compromise would allow attackers to issue trusted fraudulent certificates

(D) It affects printers

Q97: Explanation

Correct Answer: C

- Trust chains depend on CA keys.
- Offline roots and HSMs are common protections.
- Revocation procedures must exist.

Key Takeaway

CA keys are the root of trust.

Q98: Data Backup Encryption

Question

Backups are stored offsite. Which control **BEST** protects them if lost or stolen?

(A) Unencrypted storage

(B) Encryption of backups with securely managed keys

(C) Labels that say confidential

(D) No access control

Q98: Explanation

Correct Answer: B

- Encrypted backups are unreadable without keys.
- Key management is crucial.
- Access controls add protection.

Key Takeaway

Encrypt the backups, protect the keys.

Q99: Zero Trust Architecture Components

Question

Which combination **BEST** reflects a zero trust architecture?

(A) Strong identity, device posture checks, least-privilege access, segmentation, and continuous monitoring

(B) Network location as the only trust factor

(C) Shared credentials

(D) Perimeter only

Q99: Explanation

Correct Answer: A

- Trust is evaluated per request.
- Context informs decisions.
- Monitoring detects misuse.

Key Takeaway

Verify identity, device, and context continuously.

Q100: Web Session Cookies

Question

Attackers steal session cookies to take over authenticated user sessions. Which controls **BEST** reduce this risk?

(A) Long-lived cookies with no flags

(B) Sending cookies over unencrypted connections

(C) Sharing session IDs in URLs

(D) Secure and HttpOnly cookie flags, TLS, short session lifetimes, and re-authentication for sensitive actions

Q100: Explanation

Correct Answer: D

- Stolen sessions bypass passwords and MFA.
- Flags and TLS reduce theft opportunities.
- Short lifetimes limit misuse.

Key Takeaway

Protect the session as carefully as the password.

Exam Mindset Summary

Remember These Core Principles

- **Business First:** Risk is defined by its effect on business objectives.
- **Owners Decide:** Practitioners inform; owners accept, mitigate, transfer, or avoid.
- **Three Lines:** The first line owns risk, the second oversees, and the third gives independent assurance.
- **Ethics Matter:** Honesty, independence, and confidentiality underpin credible risk advice.
- **Evidence Over Opinion:** Use data, scenarios, and calibrated ratings.
- **Proportionality:** Controls should fit the risk and its cost.
- **Accountability Cannot be Outsourced:** Vendors and cloud providers share duties, but accountability remains with the organization.

Good Luck on Your CRISC Exam!

Real exam questions test your ability to apply these concepts in practical, real-world scenarios.